



AI SECURITY BEST PRACTICES GUIDE

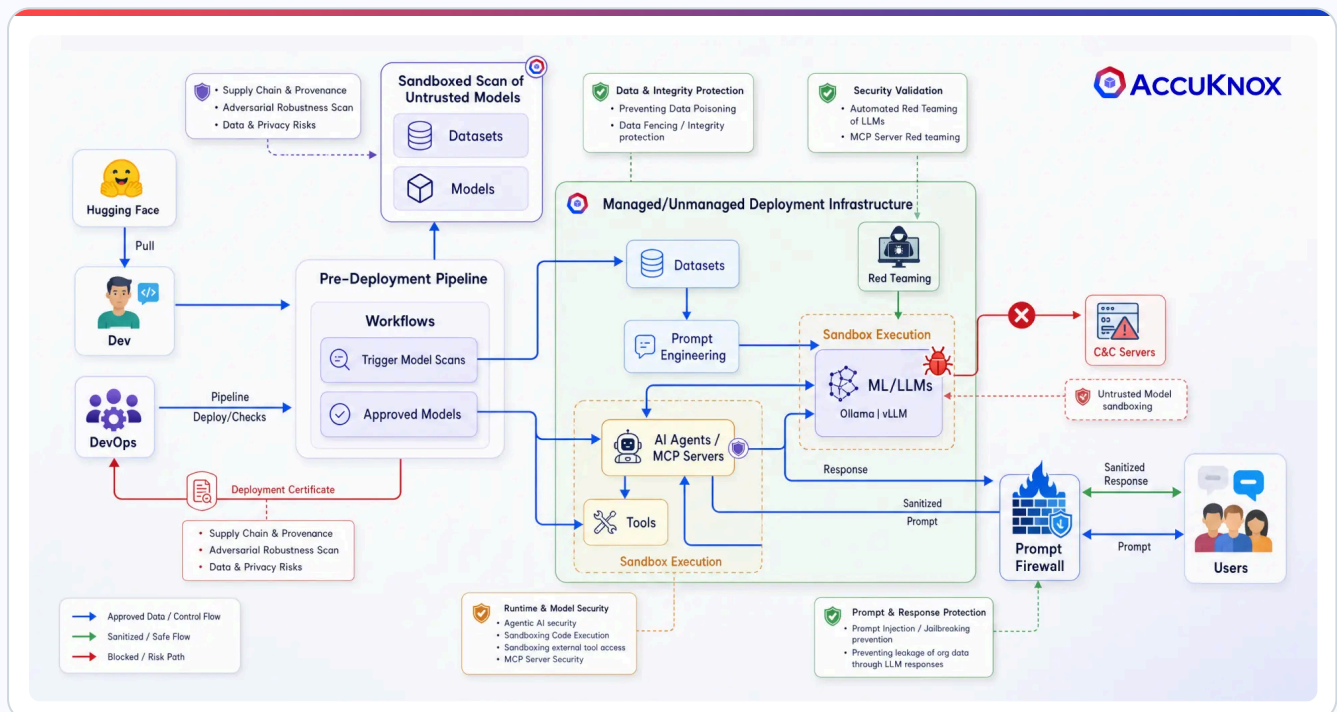
Use AI fast and keep it secure

The do's and don'ts for six AccuKnox AI security modules, with the setup page for each gap you find.

Start here

Six controls cover the AI lifecycle

Each module guards one stage, from the model you pull to the prompt your user sends. Run the six together, because each control catches what the one before it misses.



AccuKnox AI security architecture. help.accuknox.com/getting-started/ai-security-arch

01	AI-SPM and Shadow AI	03	04	AI model and dataset security	06
	Know every model, agent and MCP server			Scan a model before it loads	
02	AI-DR	04	05	AI red teaming	07
	Catch risky AI control plane changes			Attack your own LLM first	
03	Agentic AI security	05	06	Prompt Firewall	08
	Fence what an agent can touch			Inspect every prompt and response	

You cannot secure an AI asset you never found

AI-SPM and Shadow AI Discovery inventory every model, agent and MCP server in cloud and on premises.

The screenshot shows the Accuknox AI/ML Security Assets dashboard. The 'Unmanaged' tab is selected. A search bar is at the top. Below it, a table lists categories of unmanaged AI assets. Each category has a count and a bar chart showing findings across different severity levels (Critical, High, Medium, Low).

Category	Asset Count	Findings
AI Agent	26	22 Critical, 224 High, 342 Medium, 73 Low
AI Automation	37	6 Critical, 17 High
AI Gateway	9	9 Critical, 25 High, 4 Medium, 7 Low
AI Inference Engine	18	2 Critical, 6 High, 11 Medium, 1 Low
AI-ML	466	3 Critical, 104 High, 45 Medium, 4 Low
AI SDK	241	1 Critical, 8 High, 5 Medium, 9 Low

Unmanaged AI assets by category. help.accuknox.com/use-cases/shadow-ai-discovery/

DO

- Onboard every AWS, Azure and GCP account with AI Security turned on, then review the Managed tab.
- Run the VM and in cluster scanners to find unmanaged AI SDKs, gateways, agents and MCP servers.
- Assign an owner to each AI asset and triage critical findings first.
- Review the inventory every week, because teams add AI packages faster than they file tickets.

DON'T

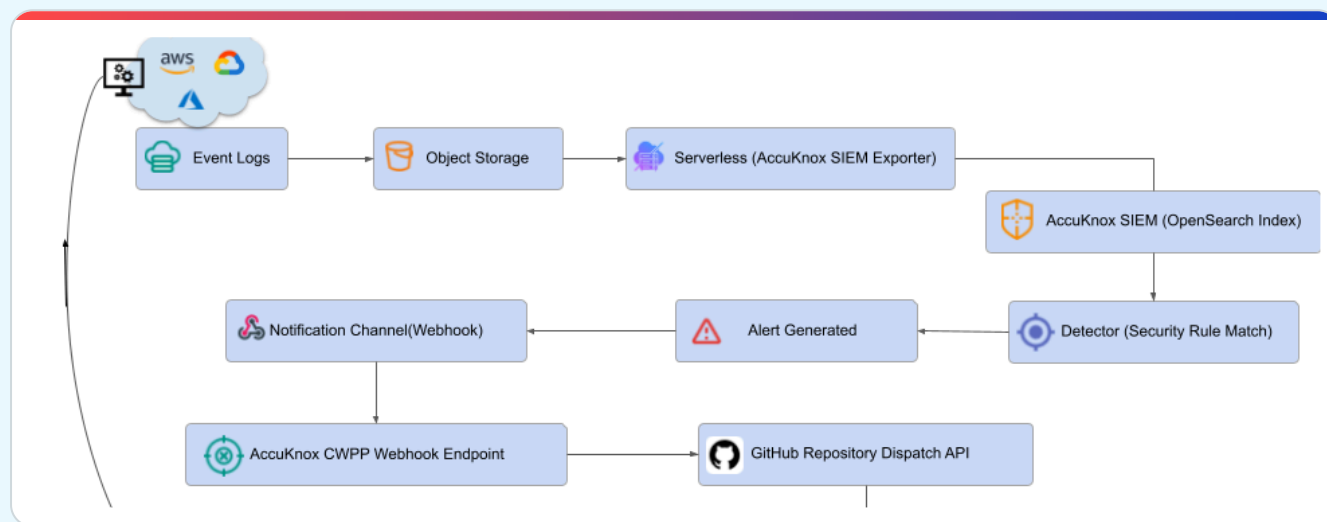
- Don't trust a spreadsheet of approved AI tools as your inventory.
- Don't scan only production. Notebooks and dev clusters hold AI packages too.
- Don't treat discovery as enforcement. Discovery shows the asset, and the other five modules control it.

HOW ACCUKNOX CLOSES THE GAP

Shadow AI Discovery connects through a read only cloud API and package level scanners, then maps each package to an AI asset type. [Set up Shadow AI Discovery](#)

Watch the AI control plane, not only the model

AI-DR reads cloud audit events and alerts on risky AI changes, such as a public SageMaker notebook.



AI-DR workflow. help.accuknox.com/use-cases/aidr/

DO

- Feed CloudTrail on AWS and Event Hub on Azure into AccuKnox for every AI account.
- Alert on new SageMaker notebooks, Bedrock customization jobs and Azure ML workspace changes.
- Route alerts to a webhook or Jira, and wire automated remediation for known bad states.
- Treat a deleted Azure OpenAI resource as a critical event and confirm who did it.

DON'T

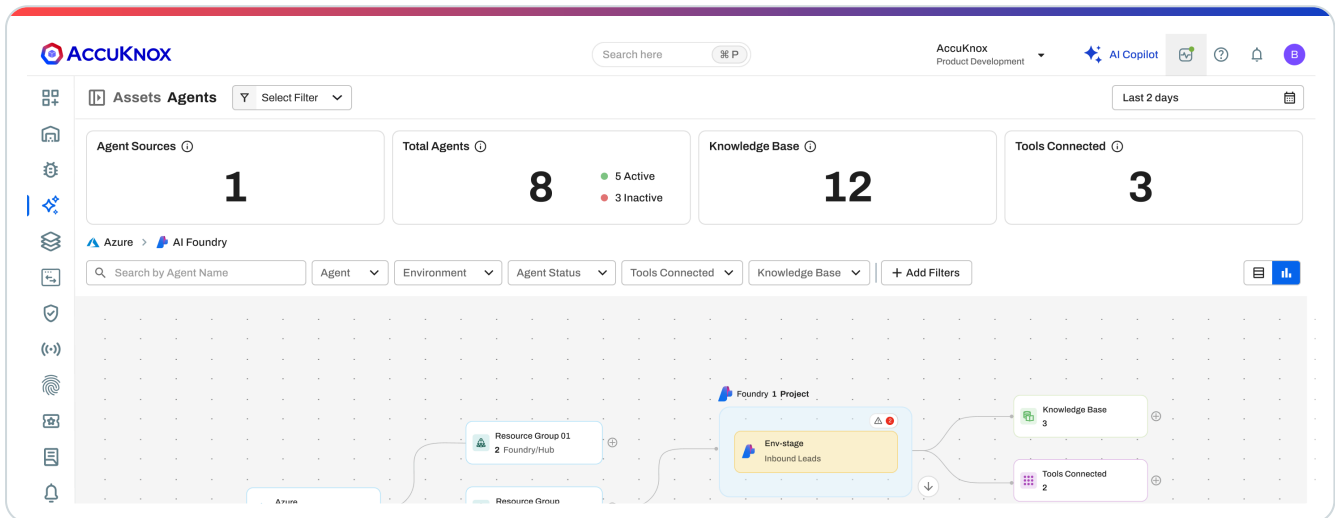
- Don't give data scientists admin rights to create public AI endpoints.
- Don't rely on AI-DR to stop a bad prompt. AI-DR runs out of band and never sits in the inference path.
- Don't let AI alerts land in a queue nobody owns.

HOW ACCUKNOX CLOSSES THE GAP

AI-DR raises the alert, opens the ticket and can trigger remediation. The Prompt Firewall covers the inference path. [Set up AI-DR on Azure](#)

Give an agent only the access its **task needs**

ModelArmor sandboxes agents and MCP servers in the kernel with eBPF and LSM, with no code change.



Agent inventory and relationship graph. help.accuknox.com/use-cases/modelarmor/

DO

- Inventory every agent, its knowledge bases and its tools before you add guardrails.
- Apply process, file system, network and domain isolation to each agent runtime.
- Allow list the domains and binaries an agent may reach, and deny the rest.
- Block reads of credential files such as **/root/.aws/credentials** from agent processes.

DON'T

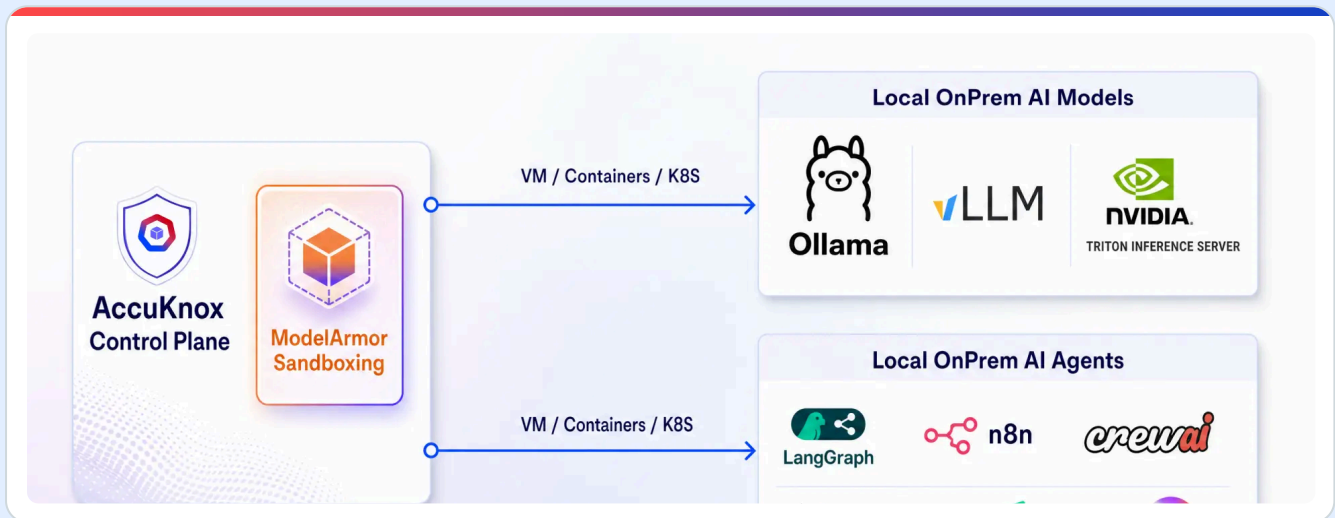
- Don't run an agent or MCP server with the host's full network and file access.
- Don't give one agent private data, untrusted content and outbound access at the same time.
- Don't install a community MCP server without review and a sandbox.

HOW ACCUKNOX CLOSSES THE GAP

ModelArmor enforces the isolation policy through KubeArmor on VMs, containers and Kubernetes, for Ollama, vLLM, Triton, LangGraph, n8n and MCP servers. [Read the ModelArmor guide](#)

Scan a model before it **loads**, not after

A model file can carry code. An unsafe pickle runs that code the moment you load it.



ModelArmor coverage for local models and agents. help.accuknox.com/use-cases/modelarmor-pickle-code/

DO

- Run ML Static Scans on every model from GitHub or Hugging Face before first use.
- Treat model file security findings, such as an unsafe pickle, as blocking.
- Gate new models in CI/CD with the `/scan` pull request comment, and merge only on a clean report.
- Rescan on every model version bump.

DON'T

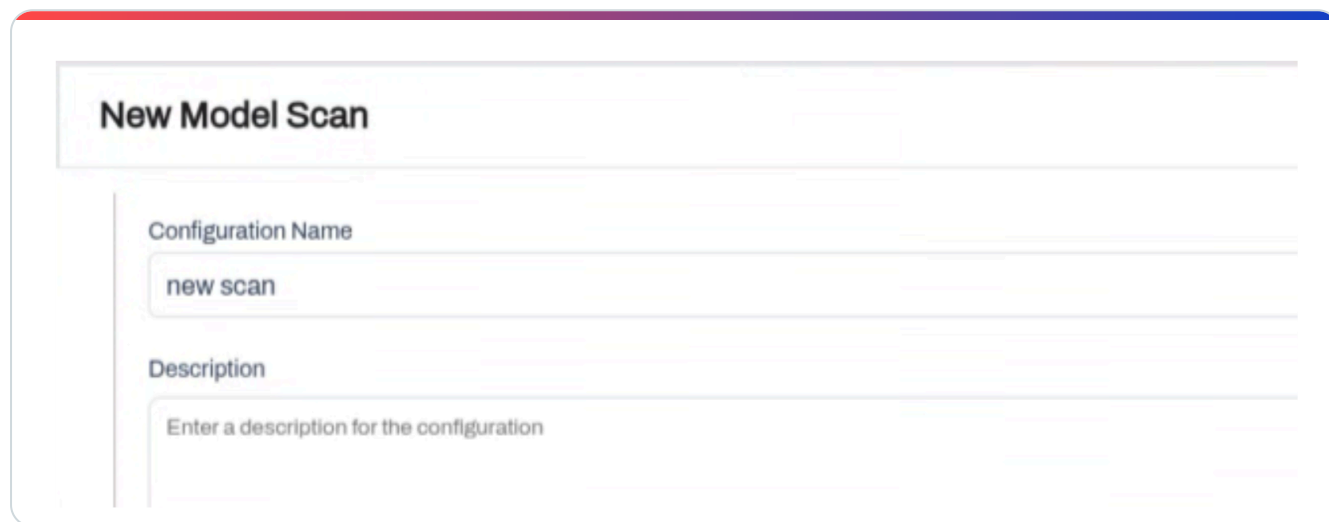
- Don't load a public model straight into a production notebook.
- Don't commit model weights to the repo. Name the model in the pull request instead.
- Don't assume a static scan covers runtime. It does not test behavior or inference time attacks.

HOW ACCUKNOX CLOSES THE GAP

ML Static Scans check supply chain, resistance to adversarial inputs, data and privacy risk and model file safety. ModelArmor contains a model at runtime. [Add model scans to CI/CD](#)

Attack your own LLM before an attacker does

Red teaming runs adversarial probes against your model and records each prompt that broke it.



New Model Scan

Configuration Name
new scan

Description
Enter a description for the configuration

New Model Scan dialog. help.accuknox.com/use-cases/red-teaming/

DO

- Scan every LLM app across Sentiment, Code, Hallucination and Prompt Injection.
- Schedule scans on a cron, and rerun after each model, prompt or config change.
- Upload your own prompts JSON to test domain risks.
- Fix findings from **Issues > Findings > LLM Findings**, and open a Jira ticket per risk.

DON'T

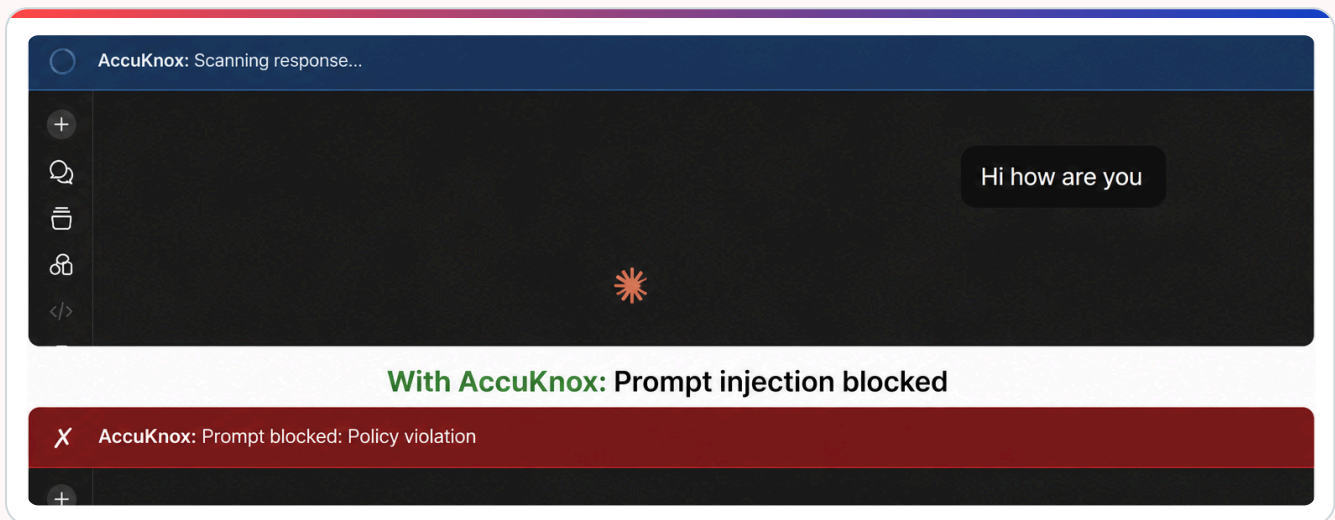
- Don't ship an LLM app after one manual test.
- Don't ignore package hallucination. A fake package name in AI generated code is a supply chain risk.
- Don't treat a clean scan as permanent. A new model version resets the result.

HOW ACCUKNOX CLOSES THE GAP

Findings map to OWASP Top 10 for LLMs and MITRE ATLAS, and each one shows the probe, the detector and the response. [Run your first red team scan](#)

Inspect every prompt and every response

The Prompt Firewall sits inline between users and the LLM, and blocks, sanitizes or monitors each message.



Prompt injection blocked by the browser plugin. help.accuknox.com/integrations/chrome-browser-integration/

DO

- Start policies in Monitor mode for one week, then move proven policies to Block.
- Turn on Anonymize, Secrets and Prompt Injection for every app.
- Pass a session ID so stateful tracking catches jailbreaks spread over many turns.
- Deploy the browser plugin to Chrome, Edge and Firefox for staff who use ChatGPT, Claude, Gemini or GitHub Copilot.

DON'T

- Don't treat the firewall as the only control. Guardrails are probabilistic and miss some attacks.
- Don't scan only prompts. Inspect responses for PII, secrets and unsafe code too.
- Don't assume the plugin covers apps. The plugin sees browser traffic only, so instrument apps through the SDK or a gateway.

HOW ACCUKNOX CLOSES THE GAP

Connect through the SDK or a gateway such as LiteLLM, Azure APIM or AWS API Gateway, and choose from 14 policy types. [Read the Prompt Firewall guide](#)

Get the speed of AI without the data leak

Security also covers how people use AI every day. Give these rules to every engineer and analyst.

DO

- Use the AI tools your company approved, signed in with your work identity.
- Mask customer data and secrets before you paste a log or a config into a prompt.
- Review AI generated code like a pull request from a new hire, then run it through your scanners.
- Check that every package an AI tool suggests exists before you install it.
- Use Ask AI in the AccuKnox console to explain a finding and draft the fix.

DON'T

- Don't paste API keys, tokens or passwords into any chat assistant.
- Don't upload confidential documents to a personal AI account.
- Don't let a coding agent run with your cloud admin credentials.
- Don't accept an AI answer about a CVE or a config without checking the source.
- Don't connect an MCP server or browser extension your security team has not reviewed.

HOW ACCUKNOX ENFORCES THESE RULES

The browser plugin applies Prompt Firewall policies to ChatGPT, Claude, Gemini and GitHub Copilot in the browser, and logs each prompt for audit. [Deploy the browser plugin](#)

Find your gap, then turn on the right module

Read each row. Where the gap is true for you, take the first step this week.

IF THIS IS TRUE	USE THIS MODULE	FIRST STEP
Nobody can list every AI model, agent and MCP server in use	AI-SPM and Shadow AI	Onboard cloud accounts and run the VM and cluster scanners
A public AI endpoint can appear with no alert	AI-DR	Stream CloudTrail or Event Hub and enable the AI rules
Agents run with full host network and file access	Agentic AI security	Apply ModelArmor isolation to each agent runtime
Public models load with no scan	Model and dataset security	Add ML Static Scans and the CI/CD model gate
LLM apps ship without adversarial tests	AI red teaming	Schedule an LLM Static Scan across all four categories
Prompts and responses reach the LLM unchecked	Prompt Firewall	Connect the SDK or a gateway, start in Monitor mode
Staff paste sensitive data into public AI tools	Prompt Firewall browser plugin	Push the plugin to managed browsers



Close your first AI gap with your CSM

Bring your gap check to your AccuKnox Customer Success Manager. Your CSM can turn on each module in your tenant and review the first findings with you.

[Email support@accuknox.com](mailto:support@accuknox.com)[Open the AI security docs](#)